

AI-Powered Enterprise E-Commerce Platform

Security Architecture Specification

Document Information

Item	Description
Project Name	AI-Powered Enterprise E-Commerce Platform
Document Type	Security Architecture
Version	1.0
Prepared By	Project Team
Status	Draft

Revision History

Version	Date	Description
1.0	DD/MM/YYYY	Initial Version

Table of Contents

- 1. Introduction
- 2. Purpose
- 3. Security Objectives
- 4. Security Principles
- 5. Security Architecture Overview
- 6. Threat Model
- 7. Authentication Architecture
- 8. Authorization Architecture
- 9. API Security
- 10. Data Security
- 11. Infrastructure Security
- 12. Container Security
- 13. Database Security
- 14. AI Security
- 15. Monitoring and Incident Response
- 16. Security Testing

- 17. Compliance Considerations
- 18. Future Enhancements
- 19. Conclusion
- 20. References

1. Introduction

Security is a critical quality attribute of enterprise systems.

This document defines the security architecture for the AI-Powered Enterprise E-Commerce Platform.

The goal is to ensure:

- Confidentiality
- Integrity
- Availability
- Accountability
- Privacy

2. Purpose

The objectives of this document are:

- Identify security requirements.
- Define security mechanisms.
- Reduce security risks.
- Protect business assets.
- Establish secure development practices.

3. Security Objectives

SEC-01

Protect customer information.

SEC-02

Protect authentication credentials.

SEC-03

Prevent unauthorized access.

SEC-04

Secure service communications.

SEC-05

Ensure system availability.

SEC-06

Detect security incidents.

4. Security Principles

The architecture follows the following principles.

Principle of Least Privilege

Users and services receive only necessary permissions.

Defense in Depth

Multiple security layers shall be implemented.

Secure by Default

Security mechanisms should be enabled by default.

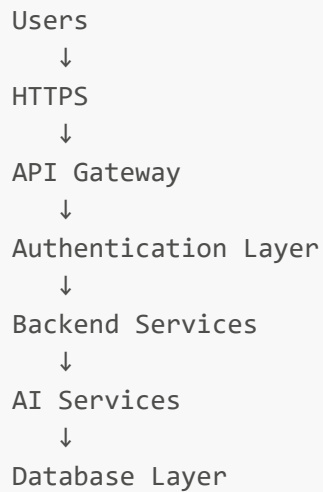
Zero Trust Mindset

No service communication is automatically trusted.

Separation of Duties

Administrative responsibilities should be separated.

5. Security Architecture Overview



Security Layers

1. Network Security
2. Authentication Security
3. Authorization Security
4. API Security
5. Data Security
6. Infrastructure Security
7. Monitoring and Auditing

6. Threat Model

External Threats

- SQL Injection
- Cross-Site Scripting
- Brute Force Attacks
- DDoS Attacks
- Credential Stuffing
- API Abuse

Internal Threats

- Privilege Misuse
- Insider Data Exposure
- Misconfigurations

AI Threats

- Data Poisoning
- Adversarial Inputs
- Model Extraction Attacks

7. Authentication Architecture

Authentication Method

JWT-Based Authentication

Authentication Flow

```
graph TD; A[User Login] --> B[Credential Validation]; B --> C[JWT Generation]; C --> D[Access Token]; D --> E[API Access];
```

Token Types

Access Token

Purpose:

Short-lived authentication.

Recommended Duration:

15–30 Minutes

Refresh Token

Purpose:

Generate new access tokens.

Recommended Duration:

7 Days

Password Security

Passwords shall be:

- Salted
- Hashed

Recommended Algorithm:

BCrypt

Password Policy

Minimum:

- 8+ characters
- Uppercase letters
- Lowercase letters
- Numbers
- Special characters

8. Authorization Architecture

Authorization method:

Role-Based Access Control (RBAC)

Roles

CUSTOMER

Permissions:

- Browse products
- Purchase products
- View orders

ADMIN

Permissions:

- Manage products
- Manage inventory
- View analytics

BUSINESS_OWNER

Permissions:

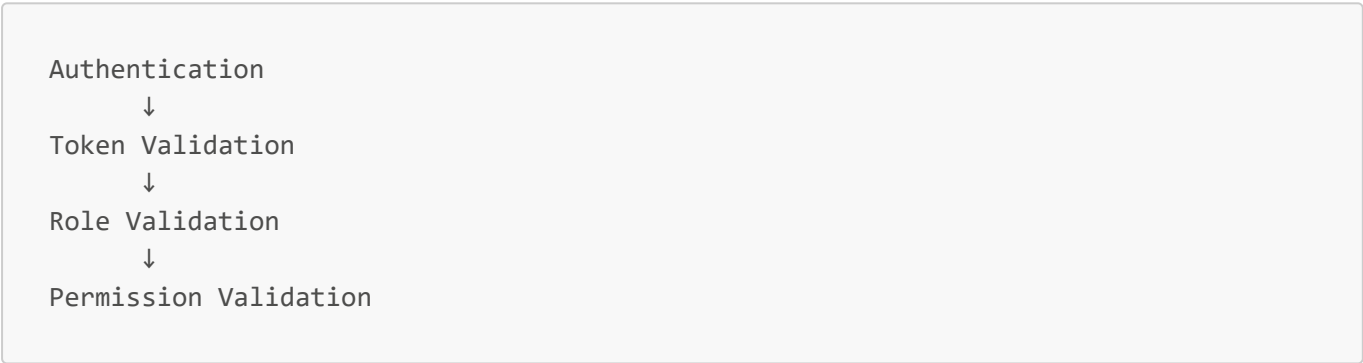
- View forecasts
- Business reports

DELIVERY_STAFF

Permissions:

- View delivery information

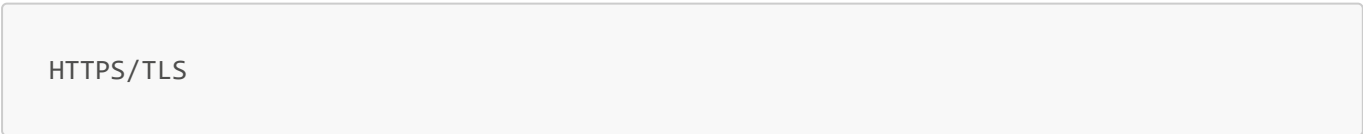
Authorization Flow



9. API Security

HTTPS Enforcement

All APIs shall use:



API Gateway Security

Responsibilities:

- Authentication
 - Authorization
 - Logging
 - Rate Limiting
-

Input Validation

Validate:

- Request bodies
 - Query parameters
 - Uploaded files
-

API Rate Limiting

Purpose:

Prevent abuse and brute-force attacks.

CORS Policy

Allow only trusted frontend origins.

Secure Headers

Examples:

```
Content-Security-Policy
X-Frame-Options
X-Content-Type-Options
```

10. Data Security

Data Classification

Public Data

Examples:

- Product catalog
-

Internal Data

Examples:

- Inventory information
-

Sensitive Data

Examples:

- User information
 - Payment details
-

Encryption Requirements

Data in Transit

Encryption:

TLS 1.2+

Data at Rest

Sensitive data should be encrypted.

Secrets

Store securely:

- API Keys
 - JWT Secrets
 - Database Credentials
-

11. Database Security

Access Restrictions

Only backend services may access databases.

Principle of Least Privilege

Separate database users.

SQL Injection Protection

Use:

- ORM
- Prepared Statements
- Parameterized Queries

Database Auditing

Log:

- Login attempts
 - Administrative changes
 - Critical operations
-

Backup Security

Backups must also be encrypted.

12. Infrastructure Security

Network Segmentation

Separate:

- Public services
 - Internal services
 - Data layer
-

Firewall Rules

Allow only required ports.

Administrative Access

Restrict using:

- VPN
 - IP Allow Lists
-

13. Container Security

Minimal Images

Examples:

```
alpine
distroless
```

Non-Root Containers

Containers should not run as root.

Container Scanning

Tools:

- Trivy
 - Docker Scout
-

Image Signing

Future enhancement.

14. Logging and Auditing

Audit logs should record:

- Authentication events
 - Authorization failures
 - Administrative activities
 - Payment activities
 - Security incidents
-

Log Retention

Recommended:

90–180 Days

15. Security Monitoring

Monitoring Tools

- Prometheus
- Grafana

- ELK Stack
-

Monitor:

- Failed logins
 - API abuse
 - High error rates
 - Unusual activities
-

16. Incident Response Process

```
Detection
  ↓
Investigation
  ↓
Containment
  ↓
Eradication
  ↓
Recovery
  ↓
Lessons Learned
```

17. Security Testing

Static Analysis

Tools:

- SonarQube
-

Dependency Scanning

Tools:

- OWASP Dependency Check
 - Snyk
-

Dynamic Security Testing

Tools:

- OWASP ZAP
-

Penetration Testing

Focus:

- Authentication
 - Authorization
 - APIs
 - Input Validation
-

18. AI Security Architecture

AI systems introduce additional risks.

Threats

- Model Poisoning
 - Data Leakage
 - Adversarial Inputs
 - Model Theft
-

Security Controls

- Dataset validation
 - Model versioning
 - Input sanitization
 - Monitoring of model drift
-

19. Compliance Considerations

Possible standards:

- GDPR principles
 - OWASP Top 10
 - OWASP API Security Top 10
 - Secure Software Development Framework (SSDF)
-

20. Security Metrics

Examples:

Metric	Target
Critical Vulnerabilities	0
High Vulnerabilities	0
Password Hashing Coverage	100%
HTTPS Coverage	100%
Audit Logging Coverage	>95%

21. Security Risks and Mitigation

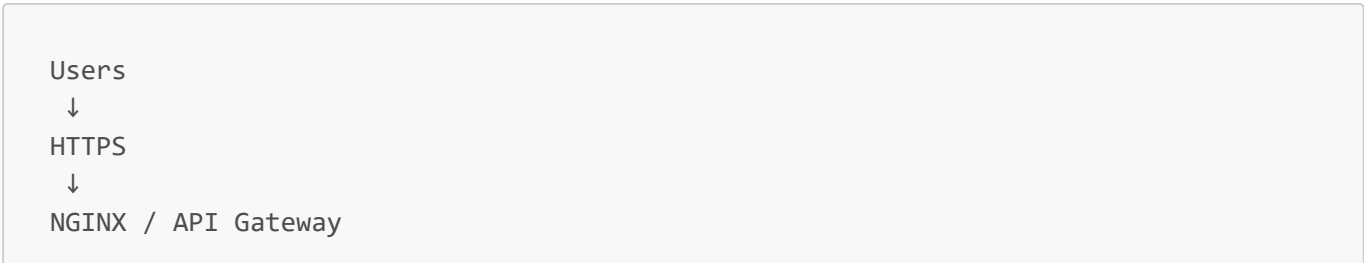
Risk	Mitigation
SQL Injection	Parameterized Queries
XSS	Output Encoding
Credential Theft	MFA (Future)
DDoS	Rate Limiting
Insider Threat	RBAC and Auditing
AI Poisoning	Dataset Validation

22. Future Enhancements

Possible improvements:

- Multi-Factor Authentication
- OAuth2/OpenID Connect
- Secrets Manager Integration
- Web Application Firewall
- Security Information and Event Management (SIEM)
- Zero Trust Architecture
- Hardware Security Modules (HSM)

23. Recommended Security Architecture Diagram



```
↓
Authentication Service
↓
Backend Services
↓
AI Services
↓
PostgreSQL
↓
Encrypted Backups
```

24. Recommended Directory Structure

```
security/
|
├── policies/
│   ├── password_policy.md
│   └── access_control_policy.md
|
├── scans/
│   ├── dependency_reports/
│   └── container_scans/
|
├── incident_response/
│   └── incident_playbook.md
|
```

25. Conclusion

The proposed security architecture provides multiple layers of protection across:

- Users
- APIs
- Services
- Infrastructure
- Databases
- AI Components

The architecture follows modern enterprise security practices and supports future scalability and compliance requirements.